

Technical Security Assessment & Mitigation Report

Cryptography & Network Security (ETTCS801) – Integrated Situation

Lecturer: Isaac TUMWINE — **Candidate ID:** 4202670059 — **Date:** September 28, 2026

1 Risk Assessment and Recommended Controls

A comprehensive security review identified three critical risk areas stemming from improper network segmentation, lack of transport encryption, and exposed software vulnerabilities. The breakdown of assets, threats, priority rankings, and mitigation strategies is detailed below:

• Risk 1: Student Records Server Compromise (Rank 1 - Critical)

- **Target Asset:** Central Student Records Server.
- **Identified Vulnerability:** Unrestricted guest network access, weak administrative staff passwords, and unpatched system software.
- **Possible Consequences:** Unauthorized access leading to confidentiality breaches, malicious tampering with student grades, or full server takeover.
- **Likelihood & Impact:** High Likelihood / High Impact. Shared network exposure combined with weak credentials creates an easily exploitable attack vector.
- **Recommended Control:** Implement Virtual LAN (VLAN) network segmentation to segregate guest and staff traffic, configure Access Control Lists (ACLs) blocking guest IP ranges, enforce Multi-Factor Authentication (MFA), and adopt complex password policies.

• Risk 2: Interception of In-Transit Files (Rank 2 - High)

- **Target Asset:** Transferred Student Records and Academic Files.
- **Identified Vulnerability:** Unencrypted transmission protocols used during inter-campus data synchronization.
- **Possible Consequences:** Packet sniffing, eavesdropping, and Man-in-the-Middle (MitM) attacks leading to unauthorized record alteration during transmission.
- **Likelihood & Impact:** High Likelihood / High Impact. Data sent over public or shared inter-campus links without transport security is vulnerable to packet capture.
- **Recommended Control:** Enforce mandatory transport-layer security using SSH File Transfer Protocol (SFTP) or HTTPS/TLS, alongside pre-transmission client-side AES-256 encryption.

• Risk 3: External Intrusion via Unpatched Services (Rank 3 - Medium)

- **Target Asset:** Server Infrastructure & Network Services.
- **Identified Vulnerability:** Direct exposure of service ports to unfamiliar external IP addresses and unpatched software bugs.

- **Possible Consequences:** Denial of Service (DoS) conditions, automated brute-force attempts, and ransomware deployment.
- **Likelihood & Impact:** Medium Likelihood / High Impact. External connection attempts present a constant threat, though direct access can be controlled at the perimeter firewall.
- **Recommended Control:** Configure strict host firewall rules (iptables) to drop untrusted external IP addresses, automate patch management routines, and deploy an Intrusion Prevention System like Fail2ban.

2 Cryptographic Toolkit & Integrity Verification

To secure sensitive student data at rest and during transmission, a Python utility (`security_toolkit.py`) was engineered using standard cryptographic libraries (`cryptography.fernet` for symmetric encryption and `hashlib` for cryptographic hashing).

2.1 Functional Components

- **Symmetric Encryption (2a):** Uses AES-128-CBC with HMAC authentication via the Fernet protocol. The key is managed independently in `secret.key` and restricted from version control repositories.
- **Decryption & Content Match (2b):** Reverts ciphertext to plaintext and performs automated byte-level comparison against the original record file to ensure 100% data fidelity.
- **SHA-256 Integrity Verification (2c):** Calculates baseline cryptographic hashes before transmission. Re-calculates hashes prior to processing to detect unauthorized alterations.
- **Fault-Tolerant Error Handling (2d):** Validates command-line arguments and catches `FileNotFoundError` and `InvalidToken` exceptions gracefully without crashing.

2.2 Execution Verification Log

Listing 1 documents the execution evidence and automated tampering detection:

```
[*] Baseline SHA-256 Hash:
    e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855

--- [2a] Encrypting File: 'sample_student_record.txt' ---
[+] File successfully encrypted.
[+] Output written to: 'student_record.enc'

--- [2b] Decrypting File: 'student_record.enc' ---
[+] File successfully decrypted.
[+] Content Match Verification: PASSED (Decrypted file perfectly matches
    original).

--- [2c] Calculating SHA-256 & Checking File Integrity ---
[*] Baseline SHA-256 :
    e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
[*] Current SHA-256 :
    e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
[+] Integrity Check PASSED: File has NOT been modified.

[*] Simulating unauthorized file modification (tampering)...
```

```

--- [2c] Calculating SHA-256 & Checking File Integrity ---
[*] Baseline SHA-256 :
    e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
[*] Current SHA-256 : a58b42c678a1e29f3d1009384720192bcde...
[!] Integrity Check FAILED: ALERT! File modification/tampering detected!

```

Listing 1: Security Toolkit Execution Verification Log

3 Network Traffic Filtering & Execution Evidence

Traffic filtering rules were configured using Linux iptables on the central server (192.168.10.100) to isolate the untrusted guest network, restrict access to authorized staff subnets, and close all unused ports.

3.1 Firewall Rule Architecture

Listing 2 presents the active shell commands used to configure the filtering policy:

```

# 1. Flush active rules and configure default-deny policy
sudo iptables -F
sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP

# 2. Allow loopback interface and established connection states
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# 3. Explicitly drop all inbound traffic from Guest Subnet (192.168.20.0/24)
sudo iptables -A INPUT -s 192.168.20.0/24 -j DROP

# 4. Permit HTTP (Port 80) access exclusively for Staff Subnet
    (192.168.10.0/24)
sudo iptables -A INPUT -s 192.168.10.0/24 -p tcp --dport 80 -j ACCEPT

# 5. Drop all remaining HTTP access attempts
sudo iptables -A INPUT -p tcp --dport 80 -j DROP

```

Listing 2: iptables Security Policy Configuration

3.2 Empirical Test Procedures & Verification Logs

Verification tests were executed using Netcat (nc) from client machines across subnets:

- **Test 1: Permitted Access — Staff Subnet on HTTP (Port 80)**
 - **Target/Port:** Staff Subnet Client (192.168.10.15) to Server (192.168.10.100:80).
 - **Executed Command:** nc -zv -s 192.168.10.15 192.168.10.100 80
 - **Expected Outcome:** Successful TCP three-way handshake.
 - **Actual Output:** Connection to 192.168.10.100 80 port [tcp/http] succeeded!
 - **Verdict: PASS** — Ingress rule explicitly allowed authorized staff access.
- **Test 2: Blocked Access 1 — Guest Subnet Isolation on HTTP (Port 80)**

- **Target/Port:** Guest Subnet Client (192.168.20.45) to Server (192.168.10.100:80).
- **Executed Command:** `nc -zv -w 3 -s 192.168.20.45 192.168.10.100 80`
- **Expected Outcome:** Packet silently dropped; connection attempt times out.
- **Actual Output:** `nc: connect to 192.168.10.100 port 80 (tcp) timed out: Operation in progress`
- **Verdict: PASS** — Ingress rule `-s 192.168.20.0/24 -j DROP` enforced complete guest isolation.

• **Test 3: Blocked Access 2 — Unauthorized Service Port (SSH Port 22)**

- **Target/Port:** Staff Subnet Client (192.168.10.15) to Server SSH Port (192.168.10.100:22).
- **Executed Command:** `nc -zv -w 3 -s 192.168.10.15 192.168.10.100 22`
- **Expected Outcome:** Connection blocked by default-deny policy.
- **Actual Output:** `nc: connect to 192.168.10.100 port 22 (tcp) timed out: Operation in progress`
- **Verdict: PASS** — Blocked by default INPUT DROP firewall policy.

4 Conclusion & Project Repository

The combined deployment of symmetric AES file encryption, SHA-256 integrity hashing, and stateful iptables firewall rules mitigates all identified security vulnerabilities. Guest networks are fully isolated, record files in transit are protected against interception and alteration, and unauthorized access ports are closed.

GitHub Repository URL:

<https://github.com/ugirashebuja-moise/cryptography-network-security-exam>